

Esercizio 2: Analisi di una Minaccia (Malware Sandbox)

1. Executive Summary

L'analisi riguarda un URL GitHub che punta a un eseguibile (Jvczfhe.exe) ospitato nel repository pubblico MELITERRER/frew. Il file, se scaricato ed eseguito, tenta di installarsi tramite un binario Microsoft legittimo (InstallUtil.exe) per eludere i controlli di sicurezza, ed è protetto da un offuscatore commerciale (.NET Reactor). Durante l'esecuzione, il processo instaura una connessione di rete verso un dominio Dynamic DNS (DuckDNS) su una porta non standard, comportamento tipico dell'infrastruttura di Comando e Controllo (C2) di un Trojan/RAT. Il verdetto finale di ANY.RUN è "Malicious activity" e il campione risulta già classificato come "Known threat" nei database di threat intelligence della piattaforma.

2. Informazioni Generali sul Campione

URL analizzato	https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe
Verdetto	Malicious activity (Known threat)
Data analisi	25 Agosto 2024, 22:38:59
Sistema operativo	Windows 10 Professional (build 19045, 64 bit)
Tag	github, netreactor
MD5	00B5E91B42712471CDFBDB37B715670C
SHA1	D9550361E5205DB1D2DF9D02CC7E30503B8EC3A2
SHA256	0307EE805DF8B94733598D5C3D62B28678EAEADB1CA3689FA678A3780DD3DF0
Durata task	300 secondi (+240 aggiuntivi)

3. Catena di Infezione (Process Tree)

La catena di esecuzione osservata è la seguente:

- firefox.exe apre il link GitHub verso Jvczfhe.exe (il browser genera numerosi processi figli, comportamento normale/interno di Firefox).
- Il file Jvczfhe.exe viene scaricato in C:\Users\admin\Downloads\ ed eseguito (PID 7492).
- Jvczfhe.exe avvia cmd.exe con il comando "timeout 21 & exit" (PID 7520), tecnica comune per introdurre un ritardo prima di proseguire l'esecuzione (probabile evasione temporale della sandbox).
- Jvczfhe.exe invoca InstallUtil.exe (PID 5152) — un binario .NET firmato Microsoft — per eseguire codice, tecnica di defense evasion nota come "System Binary Proxy Execution". Questo processo è quello che stabilisce la connessione di rete sospetta verso il C2.
- Jvczfhe.exe crasha (intervento di WerFault.exe, PID 1356) con exit code anomalo, tipico di un'eccezione .NET non gestita.
- In parallelo, dallo stesso repository GitHub dell'autore (MELITERRER/kioluu) viene scaricato ed eseguito un secondo file, Muadnrd.exe (PID 7824) — stesso hash comportamentale, stesso schema (cmd.exe con timeout, crash gestito da un secondo WerFault.exe).

4. Indicatori di Comportamento

MALICIOUS

Nessun indicatore in questa categoria specifica — il verdetto complessivo "Malicious activity" deriva dalla combinazione degli indicatori Suspicious e Info elencati di seguito, oltre alla classificazione come "Known threat" nel database di ANY.RUN.

SUSPICIOUS

- Il processo scarica ed esegue un eseguibile Windows legittimo (firefox.exe dropa contenuto eseguibile).
- Avvio di CMD.EXE per l'esecuzione di comandi (Jvczfhe.exe, Muadnrd.exe).

- Uso di TIMEOUT.EXE per ritardare l'esecuzione (tecnica anti-sandbox).
- Lettura delle impostazioni di sicurezza di Internet Explorer e dei Trust Settings di Windows.
- Esecuzione di un'applicazione che va in crash (entrambi i payload).
- Connessione a una porta non standard (InstallUtil.exe → porta 7702).
- L'applicazione si autoavvia (Muadnrd.exe).

INFO

- Lettura nome computer, lingue supportate, variabili d'ambiente, GUID macchina, impostazioni proxy e policy di sistema.
- Disattivazione dei trace log (comportamento di anti-forensics, riscontrato su Jvczfhe.exe e Muadnrd.exe).
- Creazione di file/cartelle nella directory utente (crash dump generati da WerFault.exe).
- Rilevata protezione .NET Reactor su InstallUtil.exe e Muadnrd.exe (offuscatore che complica l'analisi statica).

5. Attività di Rete e Indicatore C2

Il traffico HTTP generato da firefox.exe (richieste OCSP, controlli di connettività, aggiornamenti di sicurezza del browser) è in gran parte lecito e classificato "whitelisted". L'elemento davvero rilevante è un altro:

Il processo InstallUtil.exe (PID 5152) — che rappresenta il vettore di esecuzione reale del payload — stabilisce una connessione verso:

Dominio	egehgdhjbjhtre.duckdns.org
Indirizzo IP	91.92.253.47
Porta	7702 (non standard)
Paese IP	Bulgaria (BG)

Il modulo Network Threats di ANY.RUN segnala esplicitamente questo traffico con la regola "ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain", ripetuta più volte. DuckDNS è un servizio di DNS dinamico gratuito e legittimo, ma è estremamente comune nelle infrastrutture C2 di RAT/Trojan di base, perché permette all'attaccante di aggiornare l'IP del server di comando senza dover cambiare dominio, rendendo il blocco basato su IP inefficace nel tempo.

Da notare inoltre che sia Jvczfhe.exe che Muadnrd.exe contattano direttamente avatars.githubusercontent.com — comportamento che potrebbe indicare un ulteriore uso di infrastrutture legittime (GitHub) come canale di appoggio o staging, tecnica nota come "Living off Trusted Sites" (LOTS).

6. Mappatura MITRE ATT&CK

La piattaforma ANY.RUN, nella versione gratuita/Guest, non espone la ATT&CK Matrix visuale (funzione riservata ai piani a pagamento). Sulla base degli indicatori di comportamento raccolti nel report testuale, è comunque possibile ricostruire la mappatura alle tecniche MITRE ATT&CK corrispondenti:

Tattica	Tecnica	ID	Evidenza nel sample
Initial Access / Execution	User Execution: Malicious File	T1204.002	L'utente scarica ed esegue Jvczfhe.exe da GitHub tramite browser.
Execution	System Binary Proxy Execution: InstallUtil	T1218.004	Il payload viene eseguito tramite InstallUtil.exe, LOLBin Microsoft legittimo.
Defense Evasion	Obfuscated Files or Information	T1027	Rilevata protezione .NET Reactor su Jvczfhe.exe / Muadnrd.exe / InstallUtil.exe.
Defense Evasion	Indicator Removal: Clear Windows Event Logs	T1070.001 / T1562.002	Comportamento 'Disables trace logs' rilevato su Jvczfhe.exe e Muadnrd.exe.
Defense Evasion	Modify Registry	T1112	Scrittura di numerose chiavi di registro (HKCU/HKLM) da parte dei processi malevoli.

Discovery	System Information Discovery	T1082	Lettura nome computer, GUID macchina, valori di ambiente.
Discovery	System Network Configuration Discovery	T1016	Verifica delle impostazioni proxy di sistema.
Discovery	Query Registry	T1012	Lettura impostazioni di sicurezza di Internet Explorer e Trust Settings di Windows.
Command and Control	Non-Standard Port	T1571	InstallUtil.exe comunica su porta 7702, non standard per traffico web.
Command and Control	Dynamic Resolution	T1568.002	Connessione a dominio DuckDNS (egehgdehjbhjt.re.duckdns.org), tipico di infrastrutture C2 a basso costo.
Command and Control	Ingress Tool Transfer	T1105	Download dell'eseguibile malevolo dal repository GitHub.

7. Indicatori di Compromissione (IOC)

Tipo	Valore	Note
URL sample	github.com/MELITERRER/frew/blob/main/Jvczfhe.exe	Repository GitHub usato per hosting del payload
MD5	00B5E91B42712471CDFBDB37B715670C	Hash del file Jvczfhe.exe
SHA1	D9550361E5205DB1D2DF9D02CC7E30503B8EC3A2	Hash del file Jvczfhe.exe
SHA256	0307EE805DF8B94733598D5C3D62B28678EAEADBF1CA3689FA678A3780DD3DF0	Hash del file Jvczfhe.exe
Dominio C2	egehgdehjbhjt.re.duckdns.org	Dominio Dynamic DNS usato per il C2
IP C2	91.92.253.47:7702	Indirizzo/porta di destinazione del traffico sospetto (BG)
File droppato	C:\Users\admin\Downloads\Muadnrd.exe	Copia dello stesso payload con nome diverso
Repository secondario	github.com/MELITERRER/kioluu/blob/main/Muadnrd.exe	Secondo repo dello stesso autore, stesso payload

8. Conclusioni e Raccomandazioni

Il campione analizzato rappresenta con elevata probabilità un dropper/loader di un Trojan o RAT (Remote Access Trojan), distribuito attraverso un repository GitHub creato appositamente dall'attaccante (tecnica di ingegneria sociale che sfrutta la fiducia riposta nella piattaforma GitHub). Le caratteristiche osservate — offuscamento tramite .NET Reactor, abuso di InstallUtil.exe come LOLBin, disattivazione dei trace log e comunicazione verso un dominio Dynamic DNS su porta non standard — sono coerenti con un malware commodity orientato al furto di dati o all'accesso remoto persistente.

Raccomandazioni:

- Bloccare a livello di proxy/firewall il dominio *.duckdns.org e l'IP 91.92.253.47, salvo eccezioni operative documentate.
- Diffidare di eseguibili scaricati da repository GitHub non verificati, specialmente se il nome del file non ha relazione con lo scopo dichiarato del repository.
- Monitorare l'utilizzo anomalo di InstallUtil.exe e di altri LOLBin (es. regsvr32, rundll32, mshta) come indicatore di possibile defense evasion.
- Aggiornare le firme antivirus/EDR con gli hash IOC riportati nella sezione 7.
- Sensibilizzare gli utenti sul rischio di scaricare ed eseguire file .exe da link non verificati, anche quando ospitati su piattaforme reputate come GitHub.